Livrable — Semaine 2

Omer Atici · Projet Mini CRM · 09 Avril 2026

1. Plan de sécurité

Pour sécuriser le Mini CRM, voici les mesures que je vais mettre en place :

- **Mots de passe hashés** avec bcrypt avant d'être enregistrés en base de données. Aucun mot de passe en clair ne sera stocké.
- **Connexion via JWT** (JSON Web Token) : à la connexion, un token est généré et stocké dans un cookie httpOnly (inaccessible au JavaScript) pour éviter les vols de session.
- **Protection des routes** : un middleware vérifie le token JWT à chaque requête. Si le token est absent ou invalide, l'accès est bloqué.
- **Validation des données** avec Zod côté serveur : toutes les données envoyées par l'utilisateur sont vérifiées avant d'être traitées ou enregistrées.
- **Protection contre les injections SQL** grâce à Prisma ORM qui génère des requêtes paramétrées.
- **Limitation des tentatives de connexion** : maximum 5 essais par 15 minutes par adresse IP pour éviter les attaques par force brute.
- **Variables d'environnement** : les mots de passe et clés secrètes sont dans un fichier .env, jamais versionné sur Git.

2. Choix des technos Front / Back / BDD — Benchmark

Front-End

Framework	Facilité	Performance	Écosystème

✅ **Vue.js 3**	**Facile**	**Très bonne**	**Vite, Pinia, Vue Router**
React	Moyenne	Excellente	Très riche
Angular	Difficile	Bonne	Complet mais lourd

→ Je choisis **Vue.js 3** car c'est le framework que je maîtrise le mieux et sa syntaxe est claire et lisible.

Back-End

Framework	Facilité	Performance	Flexibilité
✅ **Node.js + Express**	**Facile**	**Très bonne**	**Totale**
NestJS	Difficile	Excellente	Bonne
Django (Python)	Moyenne	Bonne	Limitée

→ Je choisis **Node.js + Express** car c'est du JavaScript comme le front, donc je garde le même langage sur tout le projet.

Base de données

BDD	Type	Adapté au CRM	ORM utilisé
✅ **PostgreSQL**	**SQL (relationnel)**	**Oui, parfait**	**Prisma**
MySQL	SQL (relationnel)	Oui	Prisma
MongoDB	NoSQL	Non (données liées)	Mongoose

→ Je choisis **PostgreSQL** car les données du CRM sont relationnelles (un client a plusieurs devis, un devis a plusieurs lignes). PostgreSQL avec Prisma gère ça très bien.

---

3. Politique de sauvegarde

Pour éviter de perdre les données du CRM, je mets en place la politique suivante :

- **Sauvegarde quotidienne** : chaque nuit, un export complet de la base de données PostgreSQL est fait (via `pg_dump`) et envoyé sur un stockage cloud. Les sauvegardes sont conservées 30 jours.
- **Sauvegarde hebdomadaire** : chaque dimanche, un snapshot complet de tout l'environnement est conservé pendant 3 mois.
- **Versionnement du code** : le code source est poussé sur GitLab à chaque fonctionnalité terminée. L'historique Git est conservé indéfiniment.
- **Restauration** : en cas de problème, je peux restaurer la base depuis le dernier dump disponible en moins de 2 heures. La perte de données maximale serait de 24h (depuis la dernière sauvegarde).
- **Test mensuel** : une fois par mois, je teste la restauration sur un environnement de dev pour vérifier que les sauvegardes fonctionnent bien.

---

4. Roadmap prévisionnelle

Le projet est découpé en 4 phases sur 8 semaines :

Phase 1 — Semaines 1 & 2 : Socle technique + Authentification

- Mise en place du projet : Vue.js, Express, PostgreSQL, Docker
- Création du modèle User avec Prisma
- API de connexion et d'inscription
- Pages Login / Register côté front + protection des routes

Phase 2 — Semaines 3 & 4 : Gestion des clients

- Modèle Client en base (nom, email, téléphone, SIRET)
- API pour lister, ajouter, modifier et supprimer un client
- Page liste des clients avec recherche et formulaire d'ajout

Phase 3 — Semaines 5 & 6 : Devis et export PDF

- Modèle Devis en base avec les lignes de devis
- API CRUD pour les devis, avec statuts (Brouillon, Envoyé, Accepté)
- Formulaire de création de devis avec calcul automatique HT/TTC
- Export PDF du devis via Puppeteer

Phase 4 — Semaines 7 & 8 : Dashboard et mise en ligne

- Page dashboard avec les statistiques principales (CA, devis, clients)
- Audit de sécurité final
- Mise en place des sauvegardes automatiques
- Tests et déploiement de l'application